

pushing enterprises to rethink their strategies. More and more, we are seeing a shift towards hybrid models—keeping PII (personally identifiable information) data in-house, while moving less critical data to the cloud.

Now, with the rise of generative AI and large language models (LLMs), there's a heavy reliance on massive datasets to train these models—making data protection more important than ever. While the cloud seems like the obvious choice given the scale involved, it is not necessarily a straightforward solution when sensitive PII data is in the mix.

To address this, there are plenty of open source, in-house options that can help manage sensitive workflows securely. But is it really that simple? Or are there hidden complexities we need to be aware of? Let us dig in and find out.

The journey so far

The genesis of open source software was rooted in the academic and research spheres, a fitting origin given the limited knowledge and resources of that era. This initial focus nurtured vibrant user communities and forums, which proved to be fertile ground for its growth. Through effective discussions, seamless sharing, and collaborative development on emerging technologies, a strong foundation was laid.

The development of the UNIX operating system at Bell Labs stands as a significant milestone in the ascent of open source. While the software industry later embraced commercialisation through copyright, a parallel path of open source persevered, fuelled by dedicated focus and effort. The remarkable outcome of this enduring commitment is evident in the present landscape, where an impressive 96% of organisations are either maintaining or actively increasing their utilisation of open source software. With the active contributions of major technology players, open source has now firmly established itself as the new normal.

A deep dive into the current landscape

Today, many organisations include open source as a core component of their technology strategy, backed by well-defined policies and governance frameworks. These policies are designed to identify appropriate areas for open source adoption, establish standard operating procedures (SOPs) for implementation, and enforce guardrails to mitigate security vulnerabilities.

A critical aspect of this strategy is defining clear evaluation criteria for selecting the right open source technologies. Most organisations have a structured mechanism for this, and the key evaluation elements typically include the following.

Reputation and adoption: The credibility of the project and its community, as well as the presence of well-known organisations that use and support the technology.

Long-term sustainability: The availability of ongoing support, active user communities, and forums that can assist in troubleshooting and development challenges.

Governance model: The existence of a transparent and active governance structure with a strong leadership board. It's important to assess opportunities for community participation—both technical and non-technical—through contributions, advocacy, and volunteering.

Technical debt and security: A review of known technical debt, including existing security vulnerabilities, along with documented plans and timelines for remediation.

In addition to these factors, it's essential to understand the community dynamics, leadership structure, and key influencers involved in the project. Consideration should be given to how your organisation can become an active participant—potentially even an influencer—in the community, which can be crucial in steering future development and ensuring your needs are addressed.

Addressing the challenges in open source

In contrast to closed source software, which typically has established controls for development, maintenance, continuous support, and alignment with regular patches and updates, open source initially appeared less structured in these areas. This perceived lack of oversight led to scepticism among organisations regarding its widespread adoption. However, the burgeoning startup ecosystem spurred a shift as organisations sought cost-effective solutions for building products. With major players like Google and Meta actively promoting open source software, confidence grew among small and medium-sized enterprises, leading to greater acceptance.

Today, for nearly every need or problem, from everyday office tools to sophisticated large language models, an equivalent open source solution exists. In this way, open source has democratised technology, making it accessible to all and fostering greater innovation.

Furthermore, significant efforts are underway to ensure open source software maintains high common vulnerabilities and exposures (CVE) scores, with vulnerabilities being identified and patched as swiftly as in leading closed source offerings. While concerns existed about sharing extended features, permissive licensing models now largely address this by allowing organisations to protect their intellectual property.

By implementing robust internal controls through well-defined standard operating procedures (SOPs) and undergoing regular external certifications and audits like HIPAA, GDPR, ISO 27001, and SOC 2, organisations utilising open source software can effectively mitigate potential challenges.

Finally, it's important to evaluate the risks and implications should the project's licence change or the open